

# Customer Support Q&A API

A production-oriented Node.js API that authenticates support requests, grounds OpenAI answers in business policy, and returns a stable JSON contract with operational safeguards.

| DELIVERY               | PROVIDER             | SECURITY                    | QUALITY                 |
|------------------------|----------------------|-----------------------------|-------------------------|
| Authenticated REST API | OpenAI Responses API | Strong bearer auth + limits | 27 tests + 89% branches |

## Business challenge

Support teams need fast, consistent answers without exposing a paid AI endpoint directly to callers. The service must validate requests, protect credentials, control provider cost, preserve a predictable error contract, and make readiness observable.

## Implemented solution

The API accepts an authenticated customer-support question, validates and normalizes the payload, combines it with a maintained business-policy context, sends a bounded Responses API request with store: false, and returns only a completed answer with model and token-usage metadata.

## Request-to-answer flow

| 1. PROTECT                                                                                                                       | 2. VALIDATE                                                                                 | 3. ANSWER                                                                                       | 4. NORMALIZE                                                                                          |
|----------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Security headers, isolated auth-failure IP control, timing-safe bearer authentication, then authenticated paid-request limiting. | JSON parser with 32 KB limit, object schema, string type, trim, and question length bounds. | Fixed instructions, store: false, timeout, bounded retries, and completed-response enforcement. | Stable success shape and public error codes; incomplete output and provider details stay server-side. |

## Grounding approach

Business facts live in a separate support-context module. The prompt instructs the model to answer only from that context and treats the customer question as untrusted data. This creates a clear maintenance point for approved policy content and a direct path to a retrieval layer when the knowledge base grows.

## Scope and evidence

The bundled business context is fictional. Grounding is prompt-only: retrieval, citations, client connectors, and deployment infrastructure are outside this repository. The 32-case paid model evaluation is pending, so no verified live quality score, client deployment, or measured business outcome is claimed.

## API contract

Successful responses contain answer, model, and normalized usage fields. Malformed input, missing authentication, rate limits, provider failures, readiness issues, and unknown routes use documented status codes and stable JSON error identifiers.

# A backend built for predictable behavior

The portfolio project emphasizes the controls that turn a provider call into an operable API service.

| Security controls                                                                                                                                                                                                           | Provider resilience                                                                                                                                                                                                           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>- Validated independent 32-byte inbound secret</li><li>- Timing-safe bearer-token comparison</li><li>- Helmet security headers</li><li>- Explicit proxy-trust configuration</li></ul> | <ul style="list-style-type: none"><li>- SDK request timeout and bounded retries</li><li>- Incomplete and refusal responses rejected</li><li>- Stable mapping of provider errors</li><li>- Graceful process shutdown</li></ul> |

## Operational endpoints

- GET /health/live confirms that the HTTP process is running.
- GET /health/ready confirms required secret configuration.
- POST /support/ask is the authenticated, rate-limited paid endpoint.
- SIGINT and SIGTERM trigger graceful server shutdown.

## Verification evidence

27 unit and HTTP integration tests cover credentials, bounded auth tracking, authentication-before-parsing, validation, prompt boundaries, best-effort redaction, sensitive-content rejection, completed-response handling, readiness contracts, isolated rate limits, and stable errors. CI enforces 89.26% branch coverage and validates the complete OpenAPI contract plus the versioned 32-case dataset.

## Data boundary

Best-effort patterns redact detected email, phone, and long account-like numbers; explicit medical, payment/account, and credential categories are rejected before the provider call. This is not an anonymization guarantee. Responses application-state storage is disabled with store: false; separate provider abuse-monitoring retention remains subject to project data controls.

## Production rollout

Replace the bundled policy context with approved business content, move secrets to a managed store, configure TLS and proxy trust, add centralized logs and cost monitoring, choose a distributed rate-limit store for multiple instances, and run representative answer-quality and prompt-injection evaluations.

## Business value

The service provides a security-controlled API foundation between customer-facing channels and OpenAI, keeping authentication, validation, cost controls, provider behavior, and public errors consistent across future web, helpdesk, or CRM clients.

Verified locally 2026-07-17 | code commit 7b8b5b3b824611b5fa4ab5796285fa4681aafd55 | [github.com/bazhinapolly/customer-support-qna-api](https://github.com/bazhinapolly/customer-support-qna-api)